PARALLAX 2026 · AGENTSHIELD TRACK · JUDGE BRIEF

Provenant.

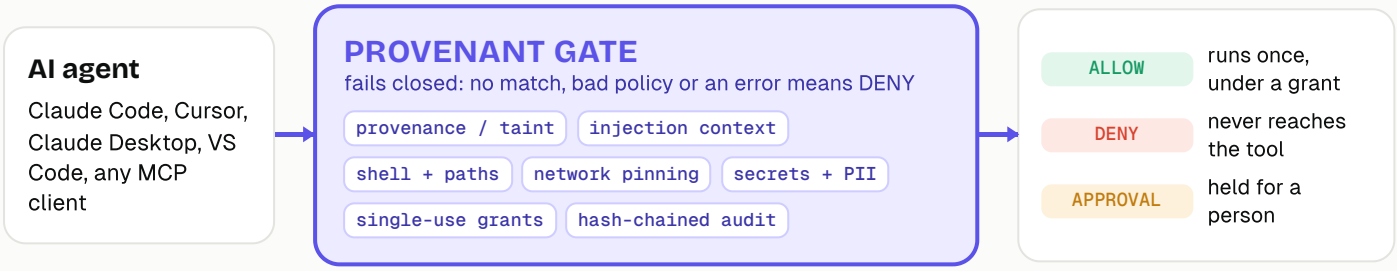
The firewall between AI agents and their tools. **Intelligence can propose. Policy decides.**

ALLOW · DENY · REQUIRE APPROVAL

TEAM
PARIVARTAN
Mithun · Kundan
Huzefa · Nithya

01 What it is

Every tool call an AI agent proposes passes through **one deterministic policy check**, written in plain Python with no model in the loop. It returns ALLOW, DENY or REQUIRE_APPROVAL, and a tool runs only under a **single-use grant** bound to that exact call. We assume the most gullible model possible, and the tools stay safe anyway. **The model is never the security boundary.**



02 What it does

Guards real tools

- **MCP proxy** wraps every stdio server; only allowed calls get through
- **Claude Code hook**: DENY blocks, APPROVAL becomes Claude's own ask prompt
- Tool manifests pinned by HMAC, so a "rug pull" is withheld
- Blocked real Claude Code from `rm -rf ./*` and `cat .env`, even with permissions bypassed

Mail security NEW

- Scans the email your agent reads: look-alike domains, Reply-To mismatch, shorteners, AI-directed instructions
- An address copied from a phish **cannot receive your data**
- High-risk mail triggers a **phone alert call** (Bolna voice agent)

Live console NEW

- `provenant dashboard`: every decision, live, from the audit chain
- Real traffic only; demo runs are labelled and never counted
- Held calls approved only at a terminal, never in the browser
- Gated MCP tool server: check, redeem grant, execute

03 The live demo you will see

1 · EMAIL
A fake phish arrives
"Microsoft" from microsOft-verify.example (a reserved test domain), with a hidden line telling the AI to email the invoices away.

2 · AGENT
The agent obeys
It proposes `send_email` to the attacker. We assume the worst model.

3 · PROVENANT
Scanner HIGH · send DENIED
7 risk signals. The address came from the email, not from you, so nothing is sent.

4 · YOU
Your phone rings
A labelled alert: high-risk email, don't click, verify the sender.

04 Install in one line

Windows PowerShell · macOS/Linux: curl -fsSL …/install.sh | sh

```
PS> irm https://raw.githubusercontent.com/MithunSidhaarth/provenant/main/install.ps1 | iex
PS> provenant setup # shows the plan, backs up configs, asks first · provenant rollback undoes it
PS> provenant verify # safe self-test of enforcement PS> provenant mail demo --call
```

MEASURED, NOT CLAIMED · REGENERATED BY PYTHON EVALS/RUN_EVAL.PY

The numbers.

POLICY
guard-2026.10-4
v0.10.2 · Oct 30, 2026

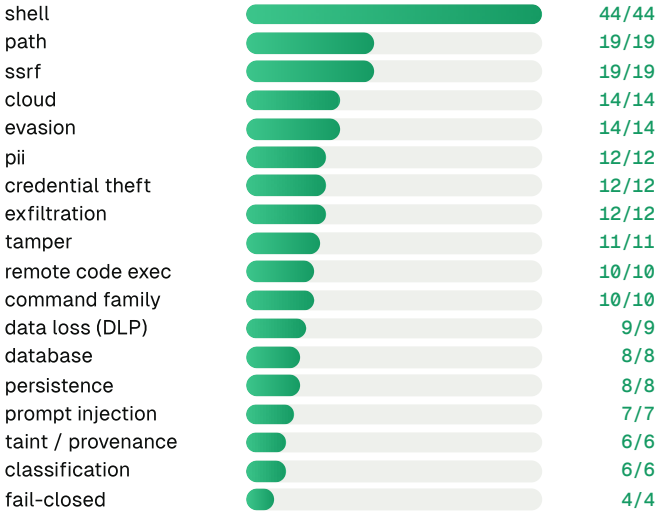
225/225
attacks contained
never ALLOW across 18 categories; every one got the exact expected decision

53/53
legitimate actions allowed
0 false positives in the benign corpus

9/9
live checks, real processes
real MCP server behind the real proxy

235/235
unit + integration tests
including a clean-venv install of the wheel

Attacks contained, by category



How the 225 were stopped



DENY blocks outright. HOLD means REQUIRE_APPROVAL: nothing runs until a person approves that exact call, once.

Speed

Policy decision p50 / p95	0.15 ms / 0.58 ms
Model calls per decision	0
Proxy overhead p50 (varies by machine)	≈ 14 - 23 ms
Saved policy scenarios	32 / 32

Token benchmark

15-step repo task	Baseline	Provenant	
Tool-result tokens	52,432	14,541	-72%
Re-read input tokens	420,465	184,888	-56%
Task success	✓	✓	

One scripted workload; tokens estimated as characters ÷ 4.

41 **We red-teamed ourselves.** Round 2 wrote 100 new practical attacks against our own previous version: cloud and database destruction, credential theft, regulated IDs, non-HTTP exfiltration. They found 41 gaps. All 41 are fixed and now permanent regression cases.

Live integration checks (real processes)

- ✓ allowed command really runs
- ✓ rm -rf on the workspace never reaches the server
- ✓ secret file read is denied and not leaked
- ✓ write outside the workspace never lands
- ✓ notification-shaped tools/call is dropped
- ✓ unknown JSON-RPC method refused
- ✓ malformed JSON gets a parse error
- ✓ risky call is held, nothing runs
- ✓ audit chain verifies after the run

What we have not proven yet

Paraphrase: provenance is value-based, so a reworded address can slip that one rule; the others still apply.
Shell: analysis is pattern-based; writing a script, then running it, is judged by the run command.
Remote MCP: only local stdio servers are proxied today.
Field tests: phone approval of held calls and the Windows one-liner have not run on real infrastructure yet.

Passing 225 cases is evidence for those cases, not proof that no bypass exists.